4. УСТАНОВКА И КОНФИГУРИРОВАНИЕ КОМПЛЕКСНЫХ АППАРАТНО-ПРОГРАММНЫХ МЕЖСЕТЕВЫХ ЭКРАНОВ (UTM/NGFW)

Ключевые слова: UTM, NGFW, KERIO CONTROL, КОНТИНЕНТ 4, IDS/IPS, АНТИВИРУС, КОНТЕНТНАЯ ФИЛЬТРАЦИЯ, КОНТРОЛЬ ПРИЛОЖЕНИЙ, ЖУРНАЛИРОВАНИЕ, МОНИТОРИНГ

Данная лабораторная работа посвящена комплексным решениям сетевой безопасности класса UTM/NGFW. Рассматриваются состав и архитектура таких решений, их отличие от межсетевого экрана на основе пакетной фильтрации, выполняются установка, настройка основных функций защиты, тестирование и анализ журналов на примере Kerio Control и отечественного комплекса «Континент 4».

В ходе данной лабораторной работы будет производиться установка и настройка UTM/NGFW-решения для защиты корпоративной вычислительной сети головного офиса.

Основной задачей является установка и сравнение двух универсальных шлюзов безопасности — Kerio Control и «Континент 4», каждый из которых объединяет межсетевое экранирование, трансляцию адресов, антивирусную проверку, фильтрацию содержимого, контроль приложений, обнаружение и предотвращение вторжений, VPN и централизованное журналирование.

В рамках проекта предстоит последовательно развернуть обе платформы на виртуальном стенде, реализовать на каждой политику безопасности для сегментов LAN, DMZ и управления, подтвердить её работоспособность тестами, а также проанализировать отчётность и журналы событий. Полученные результаты необходимо сопоставить между платформами.

1 Теоретические сведения

1.1 Что такое UTM и NGFW

Для защиты корпоративной вычислительной сети от большого количества угроз требуются комплексные решения. Такими решениями являются UTM (англ. Unified Threat Management — универсальный шлюз безопасности) и NGFW (англ. Next Generation Firewall — межсетевой экран нового поколения).

UTM — универсальное программное или аппаратное решение на основе межсетевого экрана, интегрированного с системой предотвращения вторжений (англ. IPS, Intrusion Prevention System), средствами защиты от утечек (англ. DLP, Data Leak Prevention, Data Loss Prevention), антивирусом, спам-фильтром и VPN. Главное преимущество UTM — управление безопасностью сети с помощью одного комплексного решения, что значительно упрощает администрирование. Обратной стороной является то, что сбой аппаратного или программного обеспечения такого устройства приводит к отказу сразу всех функций защиты, поэтому для UTM особенно важны резервирование и контроль нагрузки.

NGFW — межсетевой экран для глубокой фильтрации трафика, в который интегрированы механизмы IDS/IPS, а также возможность контролировать и блокировать трафик на уровне приложений. NGFW позволяет реализовать микросегментацию сети, выделив отдельные сегменты приложений. NGFW можно приобрести в виде отдельного устройства, развернуть как виртуальную машину или получить как облачный сервис.

Микросегментация — это концепция безопасности, при которой сетевой периметр дробится на изолированные зоны вплоть до уровня

отдельных рабочих нагрузок или виртуальных машин (Zero Trust подход). В отличие от VLAN, микросегментация NGFW базируется не на IP-адресах, а на логических атрибутах: тегах виртуальных машин, именах приложений или ролях пользователей.

Границы между двумя классами в современных продуктах во многом условны: большинство производителей объединяют возможности UTM и NGFW в одной системе. Основные различия приведены в таблице 1.

Таблица 1 — Сравнение UTM и NGFW

Критерий	UTM	NGFW
Основной акцент	Набор разнородных функций защиты «в одной коробке»	Глубокий анализ трафика и политики на уровне приложений и пользователей
Типичный состав	МЭ, VPN, антивирус, антиспам, веб-фильтр, IPS, иногда DLP	МЭ с контролем состояния, IPS, контроль приложений, идентификация пользователей, TLS-инспекция
Уровень анализа	L3–L7, часто потоковая проверка содержимого	L3–L7 с обязательным распознаванием приложений (DPI)
Типичный масштаб	Малый и средний бизнес, филиалы	Средний и крупный бизнес, периметр и ЦОД
Основной риск	Единая точка отказа, падение производительности при включении всех модулей	Сложность политики, ложные срабатывания, нагрузка от TLS-инспекции

1.2 От пакетной фильтрации к UTM/NGFW

Классический межсетевой экран на основе netfilter принимает решения по адресам, портам и состоянию соединения (правила iptables), а дополнительные функции (TARPIT, DELUDE, защита от сканирования портов) обеспечиваются модулями xtables-addons. Такой экран эффективен, прозрачен и полностью подконтролен администратору, но он «не видит», что именно передаётся в разрешённом соединении:

разрешённый порт 443 одинаково пропускает и легитимный сайт, и канал управления вредоносной программой.

UTM/NGFW расширяет эту модель: решение принимается не только по заголовкам пакета, но и по признакам приложения, пользователя, категории ресурса, репутации адреса и содержимому потока. Многие продукты при этом опираются на те же механизмы ядра (например, Kerio Control построен на базе ОС Linux), а новые функции добавляются поверх них в виде отдельных модулей и баз сигнатур. Сравнение подходов приведено в таблице 2.

Таблица 2 — iptables/xtables-addons и UTM/NGFW

Аспект	**iptables + xtables-addons**	**UTM/NGFW**
Критерии правил	Адреса, порты, протоколы, состояние соединения, счётчики и лимиты	Адреса, порты, пользователи и группы, приложения, URL и категории, страны (GeoIP), время
Защита от вредоносного содержимого	Невозможно средствами пакетного фильтра. Требуется отдельно устанавливать и интегрировать дополнительные модули (антивирус, прокси, IDS/IPS и др.)	Встроенные модули с обновляемыми базами сигнатур
Управление	CLI и файлы конфигурации, скрипты	Веб-интерфейс или консоль управления, шаблоны и профили политик
Отчётность	Журналы netfilter, требуется внешняя обработка	Встроенные журналы, статистика, отчёты, интеграция с syslog/SIEM
Трудоёмкость сопровождения	Высокая, зависит от квалификации администратора	Ниже, но возникают расходы на лицензии, обновления баз и контроль версий
Прозрачность и гибкость	Полная	Ограничена возможностями производителя

1.3 Основные функциональные модули

Типовой UTM/NGFW включает следующие модули:

- **Межсетевой экран с контролем состояния** — базовая фильтрация трафика между зонами (LAN, WAN, DMZ, Management) по принципу «запрещено всё, что явно не разрешено».
- **Трансляция адресов и публикация сервисов** — source NAT для выхода сети в Интернет, destination NAT (port mapping) для публикации серверов DMZ.
- **IDS/IPS** — обнаружение и предотвращение вторжений по сигнатурам и признакам аномалий. В режиме IDS система лишь фиксирует событие, в режиме IPS (inline) блокирует трафик. Режим блокировки требует тщательной настройки из-за риска ложных срабатываний.
- **Антивирусная проверка** — шлюзовая проверка файлов в протоколах HTTP, FTP, почтовых протоколах. Ограничение: зашифрованный трафик без TLS-инспекции проверить невозможно.
- **Веб-фильтрация** — разрешение и запрет по URL, категориям ресурсов, репутации, типам файлов.
- **Контроль приложений** — распознавание приложений (мессенджеры, файлообменные сети, облачные хранилища) методами глубокого анализа пакетов (DPI), независимо от используемого порта.
- **TLS-инспекция** — перехват и расшифровка HTTPS-трафика с подменой сертификата корпоративным удостоверяющим центром. Процесс представляет собой классическую атаку «Человек посередине» (англ. MitM), где шлюз динамически генерирует сертификаты для запрошенных доменов «на лету» (on-the-fly),

подписывая их корневым сертификатом корпоративного УЦ. Применение требует информирования сотрудников и соблюдения законодательства; категории с повышенной конфиденциальностью (банки, медицина, государственные сервисы) обычно исключаются из инспекции.

- **Идентификация пользователей** — привязка политик к учётным записям и группам (локальная база, Active Directory, LDAP), портал аутентификации.
- **Управление полосой пропускания** — ограничение и приоритизация трафика отдельных приложений и групп.
- **VPN** — Site-to-Site для связи с филиалами и удалённый доступ сотрудников.
- **Журналирование, мониторинг и отчётность** — хранение событий, статистика по пользователям и приложениям, оповещения, выгрузка в syslog/SIEM.

1.4 Существующие UTM и NGFW решения

На рынке присутствует множество UTM/NGFW решений: от программных до аппаратных, от открытых до платных сертифицированных. Выбор зависит от потребностей организации, бюджета и требований регуляторов.

Open Source и бесплатные решения:

- **OPNsense** — открытый исходный код, удобный интерфейс, регулярные обновления, расширенные функции безопасности; основан на FreeBSD.
- **pfSense** — Open Source платформа на базе FreeBSD; помимо межсетевого экрана и VPN поддерживает подключаемые пакеты

(например, IDS/IPS Snort или Suricata); многие функции защиты настраиваются вручную.

- **Endian Firewall Community** — бесплатное решение с функциональностью NGFW и открытым исходным кодом; ориентировано на небольшие сети, настройка сложна, при высокой нагрузке возможна низкая производительность.
- **NethSecurity** — UTM решение на базе OpenWrt с открытым исходным кодом, предназначено в основном для малого и среднего бизнеса; быстрая установка, понятный интерфейс, широкий набор функций, активная разработка.

Платные и коммерческие решения:

- **Kerio Control** — UTM для малого и среднего бизнеса, поставляется как программный или виртуальный шлюз (разработчик — GFI Software);
- **UserGate** — российский UTM/NGFW с широким набором функций безопасности;
- **Ideco NGFW** — российский программный шлюз для малого и среднего бизнеса;
- **PT NGFW** — российское решение Positive Technologies;
- **ViPNet Coordinator** — шлюзовое решение с VPN на основе отечественных криптографических алгоритмов. ViPNet использует уникальную, не основанную на IPsec технологию инкапсуляции трафика (технология ViPNet) и симметричное распределение ключей.;
- **Континент 4** — российский комплекс компании «Код безопасности» с поддержкой ГОСТ-шифрования.

Большинство решений интегрируют UTM и NGFW в одну систему, тем самым повышая общий уровень безопасности, особенно в платных программных и программно-аппаратных продуктах. Там, где таких возможностей нет изначально, возможна модульная интеграция, в особенности в Open Source продуктах (например, связка межсетевого экрана с Suricata, антивирусом и прокси-сервером).

1.5 Критерии выбора решения

При выборе необходимо обосновывать не только класс решения, но и конкретный продукт. Рекомендуется использовать критерии, приведённые в таблице 3.

Таблица 3 — Критерии выбора UTM/NGFW

Критерий	На что обратить внимание
Надёжность и отказоустойчивость	Поддержка кластера (Active/Passive), резервное копирование и восстановление конфигурации, поведение при сбое отдельных модулей
Информационная безопасность	Наличие и качество модулей защиты, частота обновления баз, история уязвимостей самого шлюза, защита интерфейса управления
Быстродействие	Пропускная способность с включёнными модулями (IPS, антивирус, TLS-инспекция): заявленная производительность одного лишь межсетевого экрана значительно выше
Трудоёмкость сопровождения	Удобство интерфейса, шаблоны политик, качество документации, наличие поддержки
Соответствие требованиям	Сертификаты ФСТЭК России на межсетевые экраны и системы обнаружения вторжений, сертификаты ФСБ России на средства криптографической защиты; актуальность сертификатов необходимо проверять в реестрах
Стоимость и лицензирование	Модель лицензирования (по пользователям, устройствам или производительности), срок подписки на обновления баз
Интеграция	Active Directory/LDAP, syslog и SIEM, SNMP, API

1.6 Kerio Control

Kerio Control — UTM-шлюз, ориентированный на малый и средний бизнес. Решение поставляется как программный шлюз (Software Appliance с собственной ОС, устанавливаемый на сервер или в виртуальную машину), виртуальный образ для платформ виртуализации и аппаратное устройство. На момент подготовки работы актуальной является линейка 9.6.x; данные в скриншотах ниже получены на версии 9.5.0, различия в интерфейсе несущественны.

Основные функции:

- правила трафика (межсетевой экран, NAT, публикация сервисов, учёт пользователей и групп);
- антивирусная проверка и защита от вредоносного содержимого;
- веб-фильтр и контроль содержимого по категориям и типам файлов;
- система предотвращения вторжений (IPS) с обновляемыми сигнатурами;
- VPN: собственный протокол Kerio VPN, IPsec, OpenVPN;
- управление полосой пропускания, балансировка и резервирование интернет-каналов;
- интеграция с Active Directory, статистика и отчёты по пользователям.

Состав модулей зависит от лицензии (подписки на обновления баз). Для учебных целей используется пробный период продолжительностью 30 дней.

1.7 Континент 4

«Континент 4» — программно-аппаратный комплекс компании «Код безопасности», относящийся к классу UTM/NGFW и поддерживающий криптографию по ГОСТ. В отличие от предыдущих версий, где механизмы

защиты были разнесены по отдельным устройствам (криптошлюз, детектор атак и др.), в четвёртой версии они объединены в едином узле безопасности. Комплекс выпускается в виде программно-аппаратных платформ и виртуального исполнения.

Основные компоненты:

- **Центр управления сетью (ЦУС)** — хранит конфигурацию и политики, управляет всеми узлами безопасности комплекса, а также выступает в роли централизованного коллектора событий ИБ (логов) со всех подчиненных узлов;
- **Узел безопасности (УБ)** — устройство, непосредственно обрабатывающее трафик; в простых конфигурациях УБ и ЦУС совмещаются на одном устройстве, подчинённые узлы подключаются к ЦУС;
- **Менеджер конфигурации / АРМ администратора** — рабочее место, с которого администратор управляет ЦУС;
- **кластер Active/Passive** — режим отказоустойчивости узлов.

Функциональные возможности (в зависимости от лицензии): межсетевое экранирование на уровнях L3, L4 и L7, контроль приложений, система обнаружения вторжений, проверка по базе вредоносных ресурсов, ограничение доступа по географическому признаку (GeoProtection), L2VPN и L3VPN с ГОСТ-шифрованием.

Политика строится на **объектах ЦУС** (сети и адреса, сервисы, пользователи, приложения, DNS-имена и др.). Правило межсетевого экрана задаёт отправителя и получателя, протокол и сервис, контролируемые приложения, действие (пропустить или отбросить) и при необходимости профиль усиленной фильтрации (с проверкой СОВ и

других модулей). Логика обработки правил классическая: последовательный просмотр сверху вниз до первого совпадения.

Правообладателем материалов «Континент 4» является компания «Код безопасности». Копирование, переработка, передача и использование материалов производителя для составления учебного практикума запрещены. Поэтому в настоящей работе **не приводятся пошаговые инструкции из документации**: для «Континент 4» формулируются задачи и критерии проверки, а конкретные действия необходимо выполнить самостоятельно по официальной документации на готовом образе виртуального стенда для ESXi. Официальную документацию и образ можно найти среди источников данной лабораторной работы.

2 Установка и первоначальная настройка Kerio Control

Ниже приведён пример установки Kerio Control на виртуальной машине (в примере — VMware Workstation). Допускается использовать иную платформу виртуализации (ESXi, VirtualBox, EVE-NG), но адресация и сегментация должны соответствовать схеме стенда из раздела 4.1.

2.1 Подготовка образа и виртуальной машины

Для установки понадобятся образ межсетевого экрана, который можно скачать с сайта производителя (рисунок 1), и виртуальная машина, на которой будет развёрнут шлюз. Для шлюза необходимо предусмотреть как минимум два виртуальных сетевых адаптера: внешний (WAN) и внутренний (LAN). В рабочей схеме лабораторной работы добавляются адаптеры для сегментов DMZ и Management либо используются VLAN. Ресурсы ВМ ориентировочно составляют 2 vCPU, 4 ГБ ОЗУ, диск 32 ГБ; точные значения следует уточнить в документации к используемой версии.

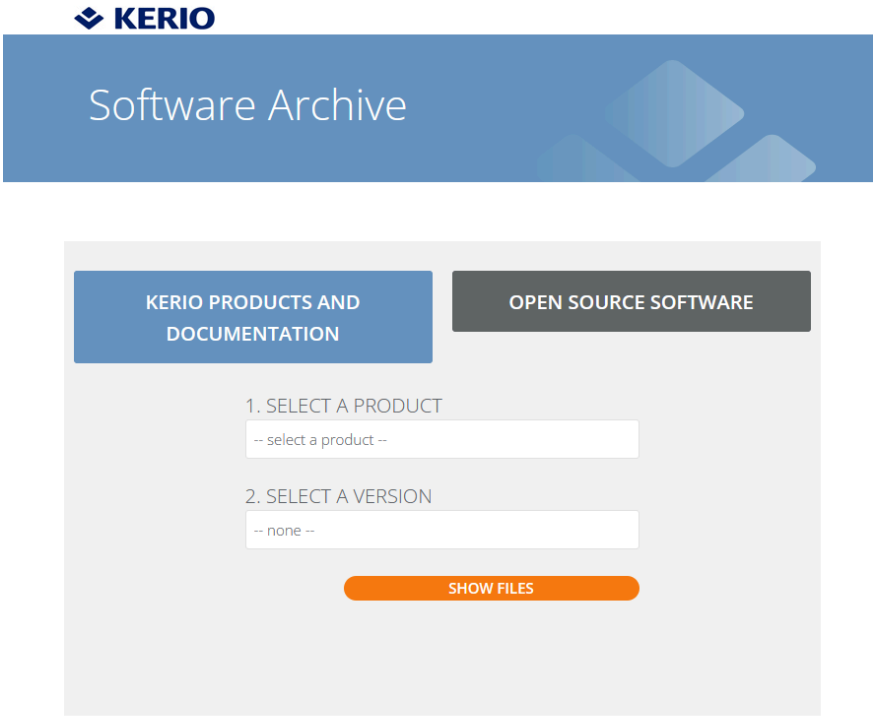


Рисунок 1 — Архив программного обеспечения Kerio (Kerio Software Archive)

2.2 Настройка сетевых интерфейсов в консоли

После запуска виртуальной машины и загрузки системы на экране отображается приветственное окно с адресом, по которому доступен веб-интерфейс для первоначальной настройки (рисунок 2). Клавиша Enter открывает консоль, а клавиша F8 позволяет сменить язык интерфейса (доступен русский язык).



Рисунок 2 — Приветственный экран консоли Kerio Control

Консольное меню состоит из пунктов «Конфигурация сети», «Удалённое администрирование», «Выключение», «Перезагрузка» и «Сброс к заводским настройкам» (рисунок 3). Первый пункт позволяет настроить сетевые интерфейсы, задав им IP-адреса и маски подсети.

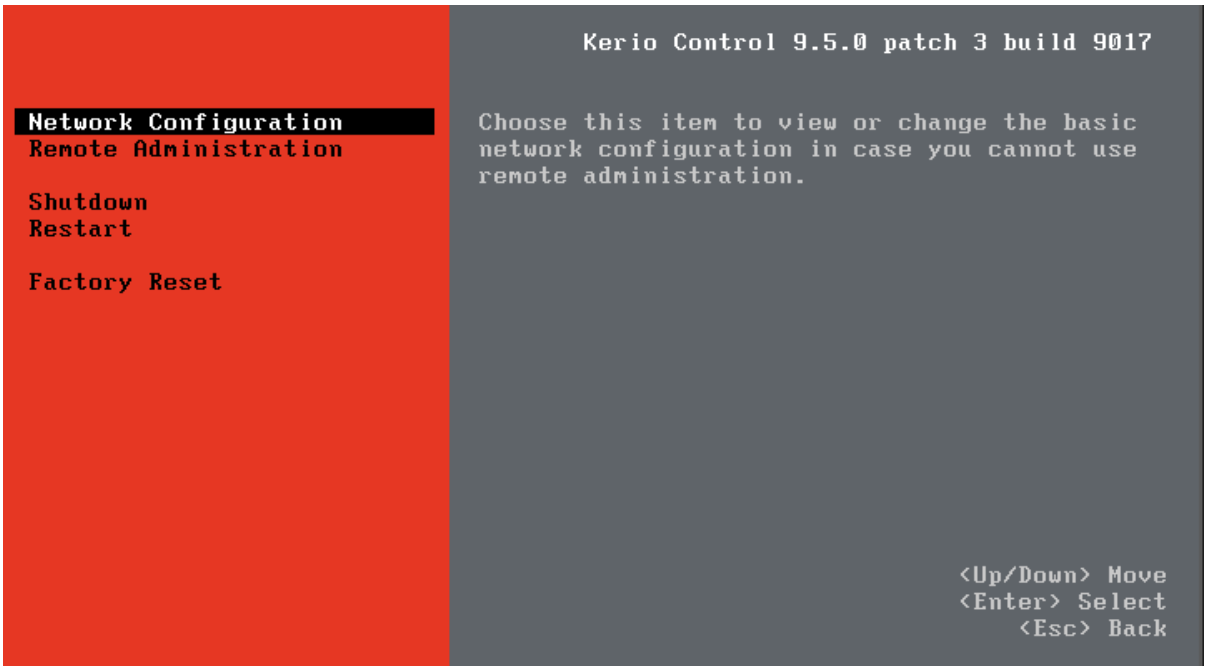


Рисунок 3 — Главное меню консоли Kerio Control

Интерфейс WAN является основным интернет-интерфейсом, выходящим в глобальную сеть (в лабораторном стенде — в сегмент, эмулирующий Интернет). Интерфейс Ethernet является локальным, через него проходит основной трафик устройств и пользователей внутренней сети (рисунок 4).

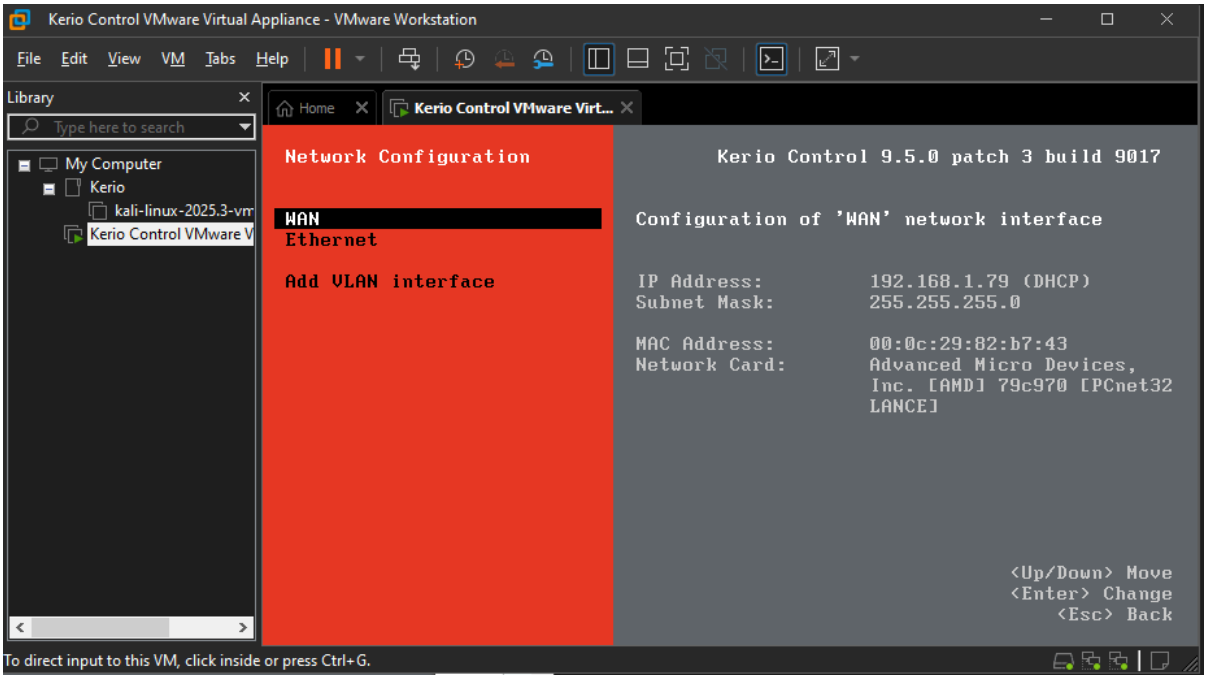


Рисунок 4 — Список сетевых интерфейсов и параметры интерфейса WAN

Для интерфейса Ethernet задаётся статический IP-адрес (рисунок 5). В примере использован адрес 10.10.10.1 с маской 255.255.255.0; в лабораторной работе адресацию необходимо принять в соответствии с таблицей 4.



Рисунок 5 — Настройка локального интерфейса со статическим адресом

Затем необходимо вернуться в главное меню и выбрать пункт «Удалённое администрирование» (рисунок 6). Этот пункт изменяет политику трафика так, чтобы доступ к администрированию был разрешён всегда, и применяется, если текущая конфигурация сети блокирует доступ к веб-интерфейсу.

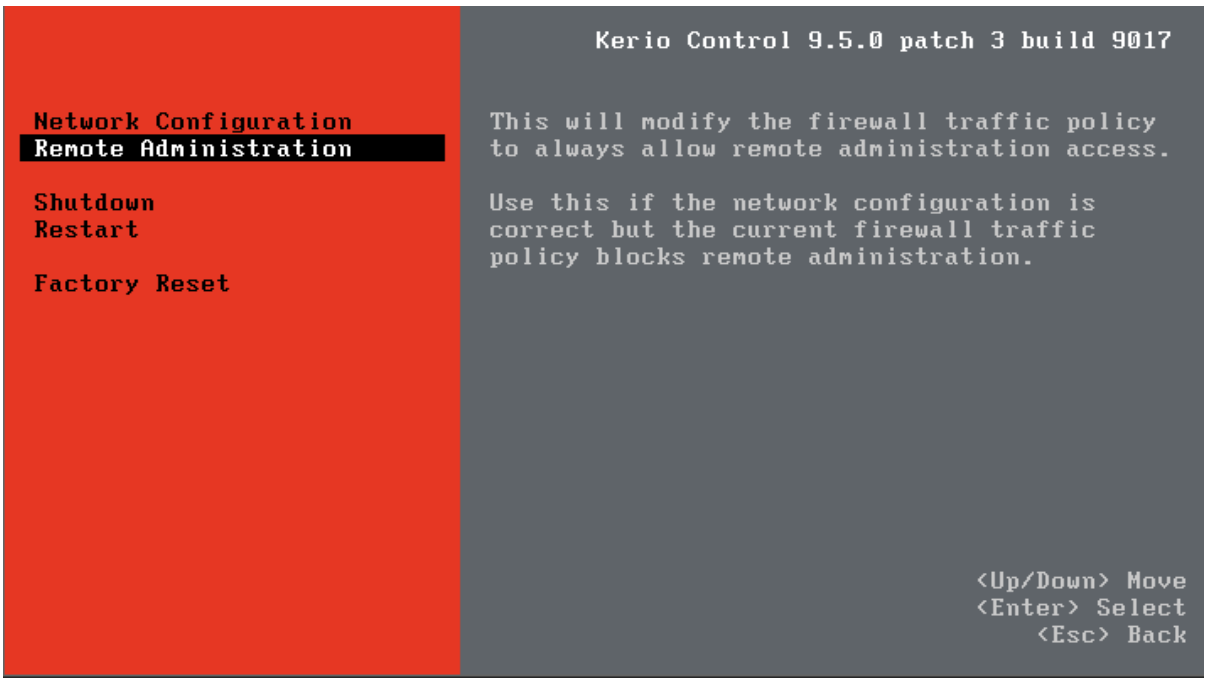


Рисунок 6 — Меню удалённого администрирования

2.3 Подключение к веб-интерфейсу и активация

Интерфейс администрирования доступен по адресу, отображаемому в консоли Kerio Control (по протоколу HTTPS на порту 4081). Так как сертификат шлюза самоподписанный, браузер выдаст предупреждение о безопасности; в условиях изолированного стенда риск принимается и выполняется переход на страницу (рисунок 7). В рабочей эксплуатации необходимо заменить сертификат на выпущенный корпоративным удостоверяющим центром.

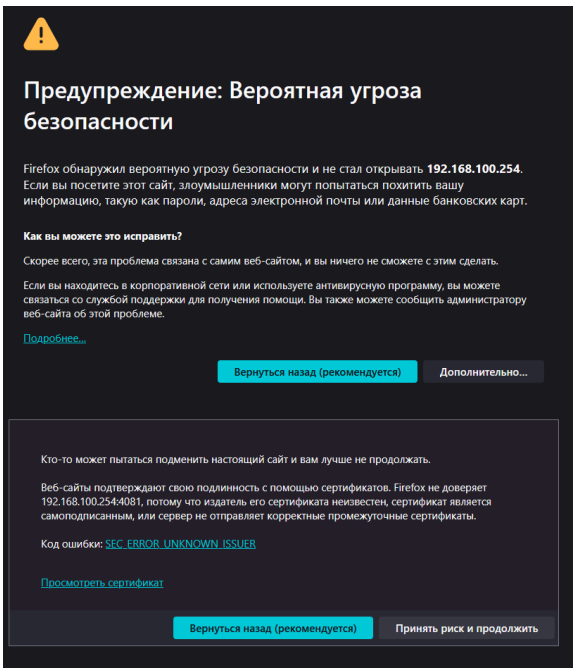


Рисунок 7 — Предупреждение браузера о самоподписанном сертификате

Следует выбрать подходящий язык и приступить к активации Kerio Control (рисунок 8).

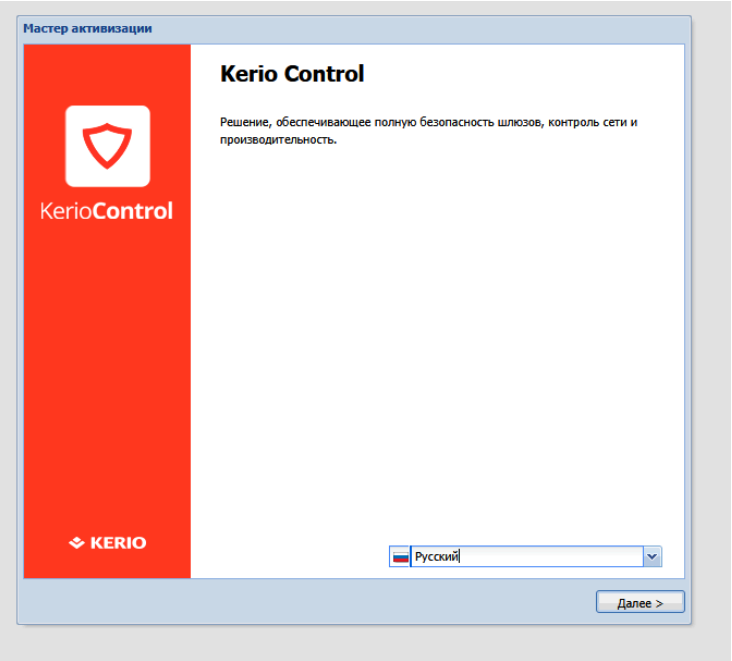


Рисунок 8 — Мастер активации, выбор языка

Если пробного ключа лицензии нет, внизу справа доступна активация без предварительной регистрации (рисунок 9). Пробный период составляет 30 дней.

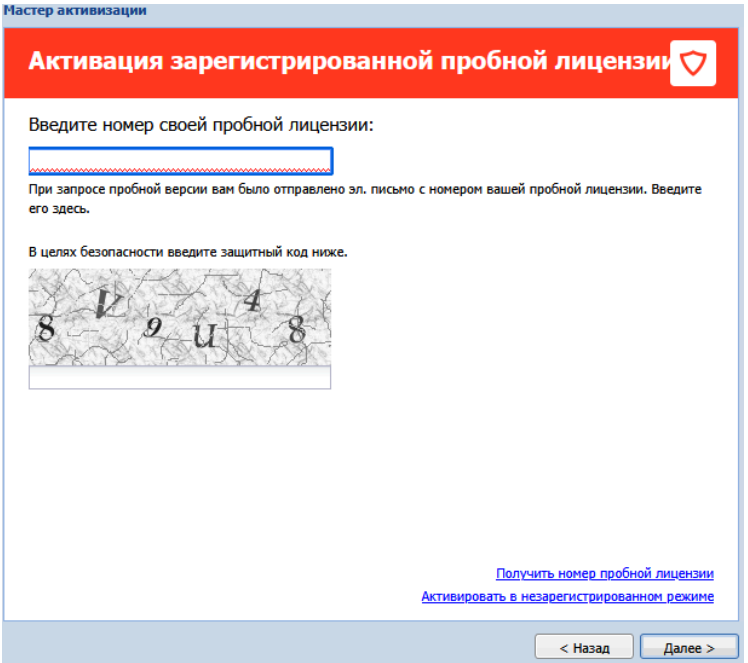


Рисунок 9 — Активация пробной лицензии

Далее необходимо задать пароль администратора (рисунок 10). Пароль должен соответствовать корпоративной политике: достаточной длины, не совпадать с паролями других систем.

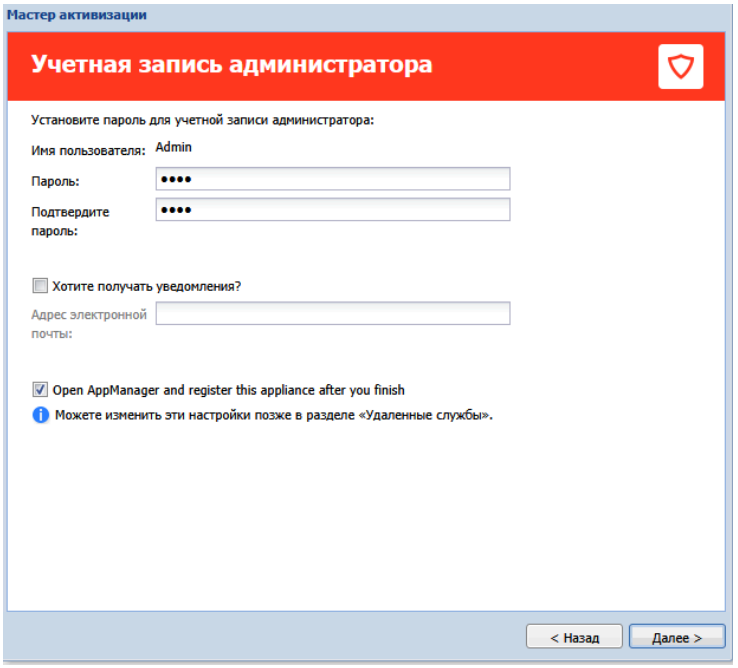


Рисунок 10 — Создание учётной записи администратора

После завершения мастера открывается интерфейс управления Kerio Control, начиная с панели мониторинга (рисунок 11).

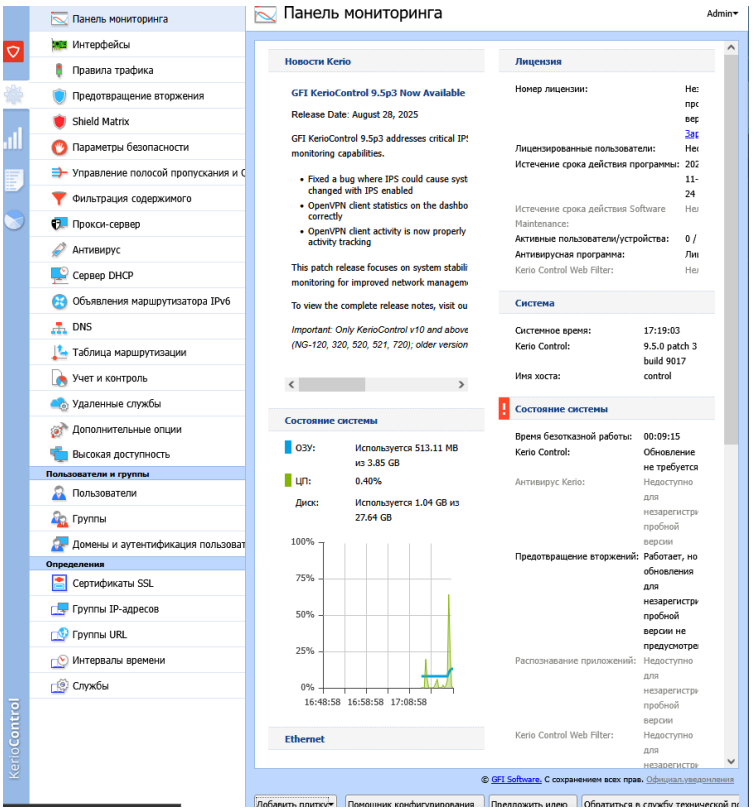


Рисунок 11 — Панель мониторинга Kerio Control

Язык интерфейса можно изменить в любой момент в правом верхнем углу окна (рисунок 12). Мастер конфигурирования (рисунок 13) помогает задать основные параметры подключения к Интернету и локальной сети, а подробные параметры интернет-подключения, в том числе режимы «один канал», «резервирование» и «балансировка нагрузки» между несколькими каналами, настраиваются в разделе «Интерфейсы» (рисунок 14).

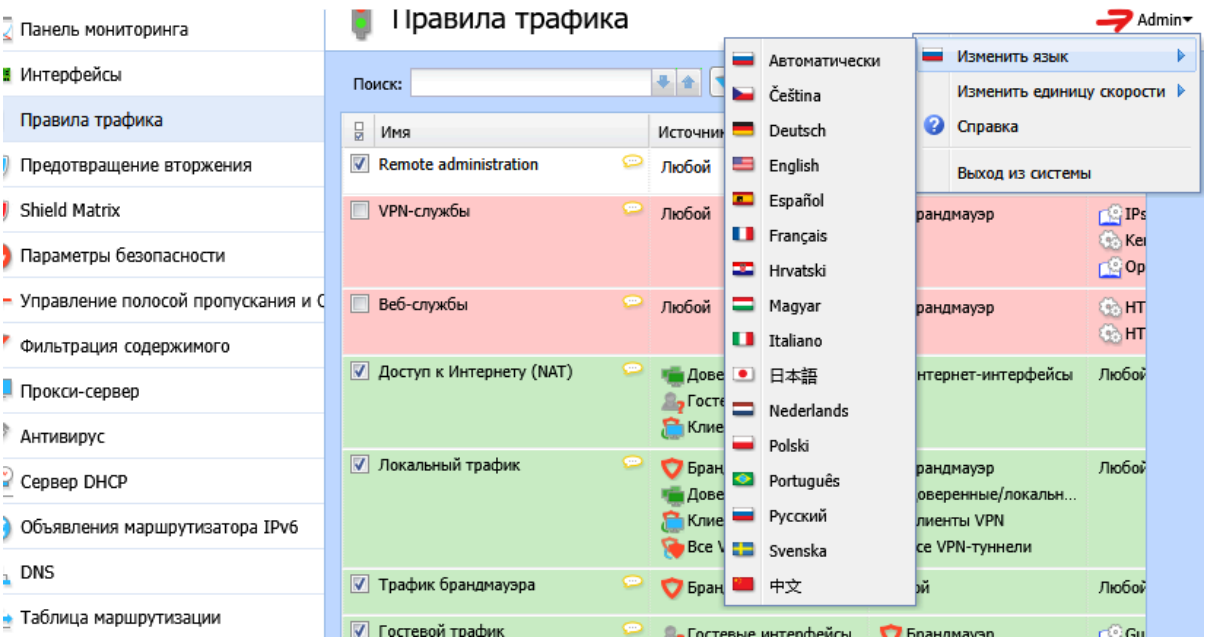


Рисунок 12 — Смена языка интерфейса

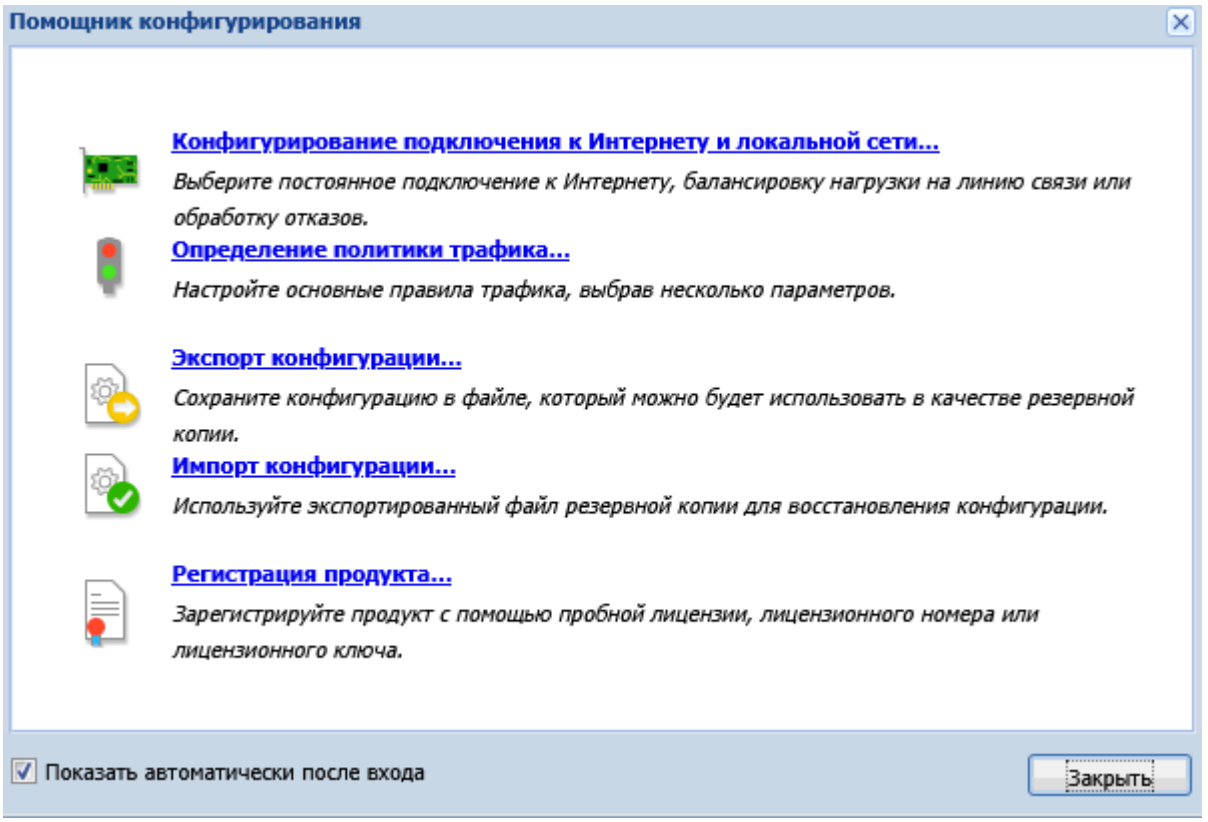


Рисунок 13 — Мастер конфигурирования

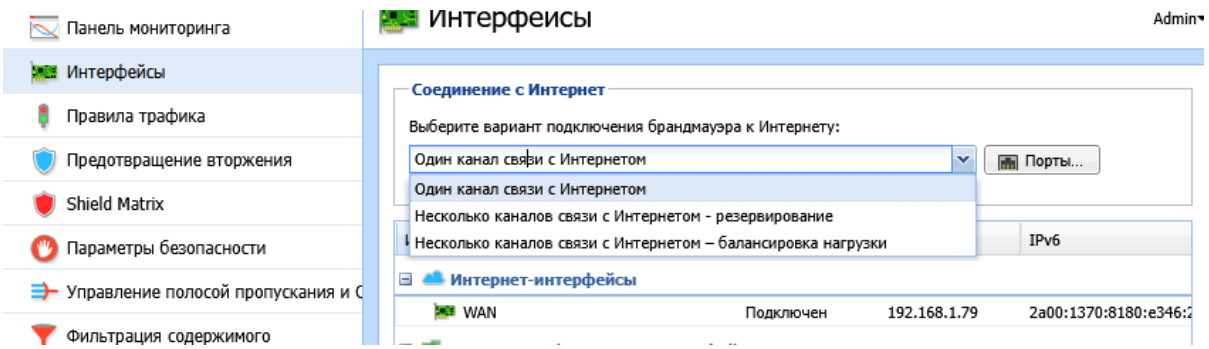


Рисунок 14 — Выбор схемы подключения к Интернету в разделе «Интерфейсы»

2.4 Первичная проверка после установки

Перед переходом к практическим заданиям необходимо убедиться, что:

- установлена актуальная версия продукта, обновлены базы сигнатур (антивирус, IPS, веб-фильтр);
- время синхронизировано по NTP (корректные метки времени критичны для анализа журналов);
- пароли по умолчанию изменены, а доступ к интерфейсу управления ограничен сегментом Management;
- в журнале и на панели мониторинга отсутствуют ошибки лицензирования и обновления.

3 Установка «Континент 4»: логика и порядок работ

Образ виртуального стенда «Континент 4» для платформы ESXi предоставляется преподавателем. Процедура установки и инициализации подробно изложена в официальной документации производителя, поэтому в настоящем практикуме она не воспроизводится. Для планирования работ достаточно понимать общую логику установки, которая для большинства конфигураций совпадает:

1. установка узла безопасности с ЦУС (УБ, совмещённый с центром управления), назначение сетевых интерфейсов и первичная инициализация;
2. подготовка рабочего места администратора (АРМ с Менеджером конфигурации) и подключение к ЦУС;
3. при необходимости — установка дополнительных (подчинённых) узлов безопасности, например, для филиала;
4. создание объектов ЦУС (сети, адреса, сервисы, пользователи) и настройка правил межсетевого экрана и NAT;
5. включение и настройка защитных модулей (контроль приложений, СОВ, проверка по базам вредоносных ресурсов, GeoProtection) через профили фильтрации;
6. создание защищённых каналов VPN между узлами (при необходимости по варианту);
7. настройка журналирования, мониторинга и резервного копирования конфигурации.

Крайне рекомендуется создавать снимки состояния (Snapshots) виртуальных машин после каждого успешного этапа базовой настройки (особенно после успешной инициализации УБ и подключения его к ЦУС).

Это позволит быстро откатиться назад в случае неверного конфигурирования без необходимости переустановки всего комплекса.

Ресурсы виртуальной машины УБ с ЦУС, по опубликованным в открытых источниках описаниям установки, составляют порядка 4 vCPU, 10 ГБ ОЗУ и 100 ГБ диска; точные требования следует определять по документации образа, предоставленного преподавателем.

4 Практическое задание

Необходимо на периметре корпоративной вычислительной сети головного офиса последовательно развернуть два UTM/NGFW — Kerio Control и «Континент 4», реализовать на каждом политику безопасности и подтвердить её работоспособность тестами. Этапы 1–8 выполняются на обеих платформах; индивидуальные задания определяются вариантом (раздел 5). В сравнительном анализе необходимо оценить платформы по критериям надёжности, информационной безопасности, быстродействия и трудоёмкости сопровождения.

Все проверки выполняются только на изолированном стенде и только в отношении собственных виртуальных машин. Использование реального вредоносного программного обеспечения запрещено: для проверки антивируса применяется стандартный безвредный тестовый файл EICAR. Сканирование и тестовые нагрузки направляются исключительно на адреса стенда.

4.1 Топология стенда и адресация

Стенд строится на платформе виртуализации (VMware, ESXi, VirtualBox или EVE-NG) и воспроизводит сегмент головного офиса с установленным на периметре UTM/NGFW (рисунок 15). На периметре поочерёдно размещается Kerio Control и «Континент 4» с одной и той же адресацией, поэтому политика и тесты на обеих платформах сопоставимы. Рекомендуемая адресация приведена в таблице 4.

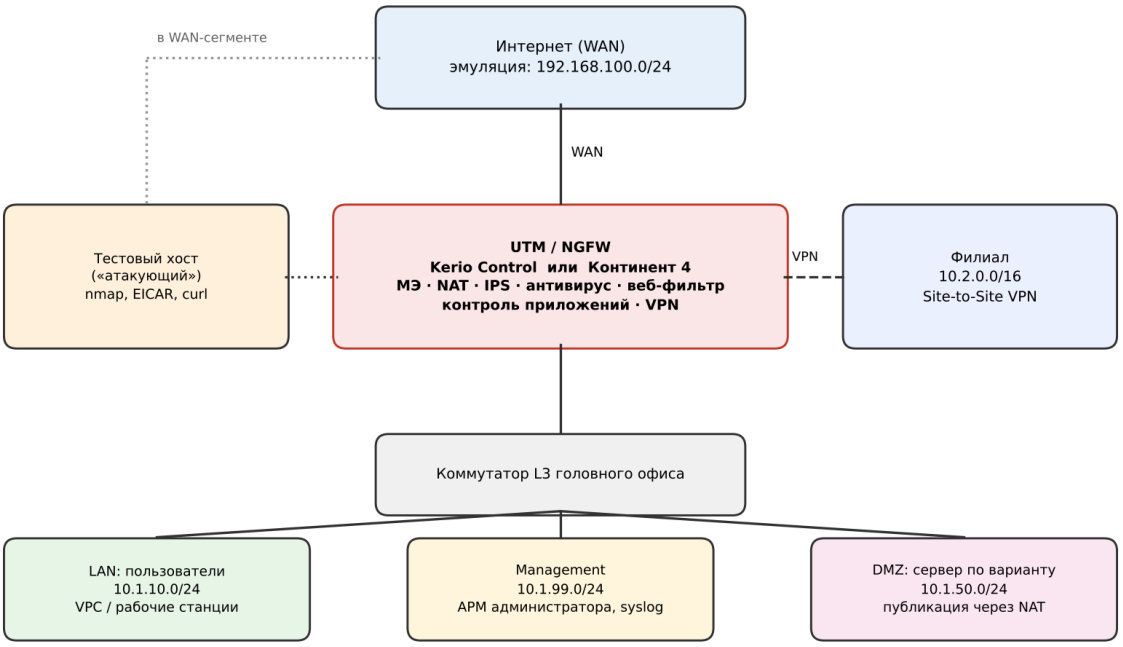


Рисунок 15 — Топология виртуального стенда

Таблица 4 — Рекомендуемая адресация стенда

Сегмент	Подсеть	Адрес шлюза (UTM/NGFW)	Узлы
WAN (эмуляция Интернета)	192.168.100.0/24	192.168.100.2	Тестовый хост («атакующий»), маршрутизатор в Интернет
LAN (пользователи)	10.1.10.0/24	10.1.10.1	Рабочие станции (VPC), группы пользователей
DMZ	10.1.50.0/24	10.1.50.1	Сервер по варианту (веб, почта и т.п.)
Management	10.1.99.0/24	10.1.99.1	АРМ администратора, сервер журналов (syslog)
Филиал (VPN)	10.2.0.0/16	через туннель	Подсеть филиала, второй экземпляр шлюза (задание по варианту)

4.2 Этап 1. Установка и базовая настройка

1. Развернуть виртуальную машину платформы (поочерёдно Kerio Control и «Континент 4»), подключить сетевые интерфейсы согласно схеме (рисунок 15) и настроить адресацию по таблице 4.
2. Обеспечить доступ администратора к интерфейсу управления только из сегмента Management; сменить пароли по умолчанию; настроить синхронизацию времени по NTP.
3. Подключить к стенду клиентов в LAN, сервер в DMZ и тестовый хост в WAN; проверить связность командами ping и traceroute.
4. Зафиксировать версию продукта, статус лицензии и дату последнего обновления баз сигнатур.

4.3 Этап 2. Политика межсетевого экранирования, NAT и DMZ

1. Реализовать политику «запрещено всё, что явно не разрешено». Разрешить: LAN → WAN (HTTP, HTTPS, DNS, NTP), LAN → DMZ (только необходимые сервисы), WAN → DMZ (только опубликованный сервис). Запретить DMZ → LAN, а доступ DMZ → WAN ограничить минимально необходимым. Для корректной работы стенда убедитесь, что тестовый хост в WAN и сервер в DMZ используют соответствующие интерфейсы NGFW в качестве шлюза по умолчанию. Без этого ответный трафик не вернется на межсетевой экран.
2. Настроить трансляцию адресов: source NAT для выхода LAN в Интернет и публикацию сервера DMZ (destination NAT / port mapping) по варианту.

3. Включить журналирование отброшенных пакетов, проверить порядок обработки правил и убедиться, что более общее правило не перекрывает более строгое.
4. Составить итоговую таблицу правил и NAT для каждой платформы и сопоставить принципы построения политики (зоны, объекты, порядок обработки правил).

4.4 Этап 3. Защита от вредоносного содержимого

1. Включить антивирусную проверку на шлюзе для доступных протоколов (HTTP, FTP, при наличии — почтовые протоколы) и обновить базы.
2. Проверить работу, скачав со стенда файл EICAR по HTTP: загрузка должна быть заблокирована, а событие — зафиксировано в журнале.
3. Проверить поведение при передаче EICAR в архиве и по HTTPS без TLS-инспекции; объяснить результат в отчёте.

Пример проверки на тестовом хосте (адрес тестового сервера условный):

```
curl -I http://10.1.50.10/eicar.com
curl -o /dev/null -w "%{http_code}\n" http://10.1.50.10/eicar.com
```

4.5 Этап 4. Фильтрация содержимого и контроль приложений

1. Создать группы пользователей (например, «Администраторы», «Бухгалтерия», «Гости») и привязать к ним политики доступа.
2. Настроить фильтрацию по категориям и URL, а также по типам файлов в соответствии с вариантом; предусмотреть исключение для группы администраторов.

3. Настроить контроль приложений (мессенджеры, файлообменные сети, облачные хранилища и т.п.) по варианту; убедиться, что запрет работает независимо от используемого порта.
4. Если по варианту предусмотрена TLS-инспекция, выпустить сертификат корпоративного удостоверяющего центра, установить его на клиентские машины и проверить, что фильтрация работает для HTTPS. Исключить из инспекции категории с повышенной конфиденциальностью. Без инспекции решение видит только доменное имя (SNI) — зафиксировать это в отчёте.

4.6 Этап 5. Обнаружение и предотвращение вторжений (IDS/IPS)

1. Включить IDS/IPS, обновить сигнатуры; сначала запустить режим обнаружения (только журналирование), затем режим предотвращения (блокировка).
2. Выполнить тестовые воздействия из WAN и LAN на сервер DMZ: сканирование портов (например, `nmap -sS`, `nmap -sV`), тестовые запросы с признаками веб-атак (имитация SQL-инъекции и обхода каталогов в параметрах URL с помощью curl) в объёме, достаточном для срабатывания сигнатур. Для проверки сигнатур сетевого уровня используйте утилиту hping3, например, выполнив атаку SYN-flood или отправив пакеты с нестандартными TCP-флагами (XMAS scan).
3. Зафиксировать реакцию системы в журнале; сравнить реакцию двух платформ: чем отличаются скорость обнаружения, поведение при блокировке и информативность записей.
4. Найти и разобрать ложное срабатывание (например, легитимный запрос, попавший под сигнатуру), настроить исключение и

объяснить, почему блокировка без исключений недопустима в промышленной эксплуатации.

4.7 Этап 6. VPN (по варианту)

Если вариант предусматривает VPN, необходимо настроить Site-to-Site подключение между головным офисом и филиалом либо подключение удалённого пользователя к сети головного офиса. Для Site-to-Site необходимо согласовать параметры (подсети, режим, алгоритмы шифрования) с филиалом, выбрать маршрутизацию подсетей через туннель и убедиться, что правила межсетевого экрана корректно применяются к трафику между офисами. Для этого необходим второй экземпляр шлюза той же платформы, имитирующий филиал.

4.8 Этап 7. Тестирование

Для подтверждения работоспособности политики необходимо составить и выполнить набор тестов, приведённый в таблице 5 (минимальный набор; дополнительные тесты добавляются по варианту). Для каждого теста приводится скриншот результата и соответствующей записи в журнале.

Таблица 5 — Минимальный набор тестов

№	Проверка	Действие	Ожидаемый результат
1	Доступ LAN → Интернет	Открыть разрешённый сайт с рабочей станции LAN	Доступ есть, трансляция адресов работает
2	Публикация сервиса DMZ	Обратиться из WAN к опубликованному сервису	Доступ разрешён только к опубликованному порту
3	Изоляция DMZ → LAN	Попытаться подключиться из DMZ в LAN	Соединение блокируется, событие в журнале
4	Антивирус	Скачать тестовый файл EICAR	Загрузка блокируется, запись об обнаружении

№	Проверка	Действие	Ожидаемый результат
5	Веб-фильтр	Открыть ресурс запрещённой категории (по варианту)	Доступ блокируется, виден пользователь и категория
6	Исключение для администратора	Повторить тест 5 под учётной записью администратора	Доступ разрешён
7	Контроль приложений	Запустить запрещённое приложение (по варианту)	Приложение заблокировано независимо от порта
8	IDS/IPS: сканирование	Выполнить nmap из WAN по адресу DMZ	Сканирование обнаружено, в режиме IPS ограничено
9	IDS/IPS: веб-атака	Отправить тестовый запрос с признаками атаки	Срабатывание сигнатуры, запись в журнале
10	Доступ к управлению	Попытаться открыть интерфейс управления из LAN и WAN	Доступ только из сегмента Management

4.9 Этап 8. Отчётность и мониторинг

1. Настроить отправку журналов на сервер в сегменте Management (syslog) и оповещения (электронная почта или SNMP) о срабатывании IPS и антивируса.
2. Получить не менее трёх различных отчётов или статистических представлений (по пользователям, по приложениям или категориям, по заблокированным событиям, по нагрузке на каналы) и объяснить, какие управленческие и технические выводы из них можно сделать.
3. Провести разбор инцидента: по метке времени теста IPS найти событие в журнале, определить источник, получателя, сработавшую сигнатуру и принятое действие.
4. Сохранить резервную копию конфигурации, внести намеренное изменение и восстановить конфигурацию из копии.

4.10 Этап 9. Сравнительный анализ

Необходимо заполнить сравнительную таблицу Kerio Control и «Континент 4» по критериям: надёжность и отказоустойчивость,

информационная безопасность, быстродействие, трудоёмкость сопровождения. Выводы должны опираться на результаты собственных экспериментов (время настройки, удобство управления, наличие и информативность журналов, поведение при тестовых воздействиях, доступность функций по лицензии), а не на общие утверждения.

5 Варианты заданий

Вариант выдаёт преподаватель. Все задания варианта выполняются на обеих платформах — Kerio Control и «Континент 4». Этапы 1, 2, 7 и 8 общие для всех вариантов; в таблице 6 указаны сервис в DMZ, требования к фильтрации содержимого и приложений (этапы 3–4), а также защитное и дополнительное задание (этапы 5–6). Если требуемый в варианте модуль недоступен на одной из платформ (не лицензирован или отсутствует на стенде), этот факт фиксируется в отчёте, а задание по согласованию с преподавателем заменяется эквивалентным.

Таблица 6 — Варианты заданий

№	Сервис в DMZ	Фильтрация содержимого и приложений	Защита и дополнительное задание
1	Веб-сервер (HTTP/HTTPS)	Блокировка категорий «Социальные сети» и «Азартные игры» для всех, кроме группы администраторов	IPS в режиме предотвращения: обнаружение и блокировка сканирования портов из WAN; ограничение доступа к DMZ по странам (GeoIP)
2	Почтовый сервер (SMTP, IMAP)	Запрет скачивания исполняемых файлов и архивов по HTTP для группы «Гости»	Обнаружение тестовых сигнатур веб-атак; блокировка QUIC (UDP/443) для корректной работы веб-фильтра
3	Веб-сервер на нестандартном внешнем порту (8443 → 443)	TLS-инспекция с корпоративным сертификатом; исключение для категорий «Банки» и «Здоровье» (если платформа поддерживает)	Удалённый доступ администратора по VPN только в сегмент Management (если платформа поддерживает)
4	Веб-сервер	Антивирусная проверка HTTP и FTP; блокировка скачивания тестового файла EICAR	Site-to-Site VPN с филиалом (второй экземпляр шлюза той же платформы)
5	DNS-сервер	Разграничение доступа в Интернет по расписанию (рабочие часы) для разных групп пользователей	Резервирование WAN-канала (если поддерживается); разбор и устранение ложного срабатывания IPS
6	Веб-сервер	Контроль приложений: запрет мессенджеров и файлообменных сервисов для группы «Гости»	Ограничение доступа к DMZ по географическому признаку; сравнение результата с вариантом без ограничения

№	Сервис в DMZ	Фильтрация содержимого и приложений	Защита и дополнительное задание
7	Почтовый сервер	Запрет группы доменов (по DNS-имени или URL) для сегмента LAN	Профиль IPS в режиме блокировки; проверка сканированием nmap из WAN и из LAN
8	Веб-сервер	Правила на основе пользователей и групп (локальная база)	Аутентификация пользователей при выходе в Интернет (портал аутентификации, если поддерживается)
9	Веб-сервер	Контроль приложений и категорий для разных групп пользователей	Site-to-Site VPN с филиалом и правила на трафик между офисами
10	Файловый сервер	Разграничение доступа LAN → DMZ по пользователям и сервисам	Анализ журналов и составление отчёта об инциденте по результатам тестов IPS

6 Структура отчёта

1. Цель работы.
2. Краткая характеристика платформ Kerio Control и «Континент 4» и критерии их сравнения.
3. Топология стенда и схема адресации (рисунок и таблица), параметры виртуальных машин.
4. Установка и базовая настройка: скриншоты интерфейсов, версия продукта, состояние лицензии.
5. Политика безопасности: таблицы правил межсетевого экрана и NAT для каждой платформы.
6. Настройка антивируса, фильтрации содержимого, контроля приложений и IDS/IPS (по этапам 3–5) на каждой платформе с обоснованием параметров.
7. Результаты тестирования: заполненная таблица тестов со скриншотами результатов и записей журнала.
8. Отчётность и мониторинг: настройки журналирования, отчёты, разбор инцидента.
9. Выполнение индивидуального задания варианта.
10. Сравнительный анализ Kerio Control и «Континент 4».
11. Заключение: выводы, ограничения решения, рекомендации.

7 Контрольные вопросы

1. Чем UTM отличается от NGFW? Почему в современных продуктах эта граница размыта?
2. Почему межсетевой экран с контролем состояния не обнаруживает атаку в разрешённом HTTP-трафике? Какие модули UTM/NGFW закрывают этот пробел?
3. Что такое DPI? Чем идентификация приложений отличается от фильтрации по номерам портов?
4. Чем отличаются режимы IDS и IPS? Что такое ложное срабатывание и как с ним работают на практике?
5. Зачем при TLS-инспекции нужен корпоративный удостоверяющий центр? Каковы технические и правовые риски этой технологии?
6. Что может и чего не может проверить шлюзовой антивирус? Почему важно проверять и конечные узлы?
7. Почему UTM считается единой точкой отказа? Какие меры снижают этот риск?
8. Как соотносятся трансляция адресов (DNAT) и правила межсетевого экрана? В каком порядке обрабатывается трафик, идущий в DMZ?
9. Какие компоненты входят в «Континент 4»? Для чего центр управления сетью отделён от узлов безопасности?
10. Для чего применяются сертифицированные средства криптографической защиты и ГОСТ-алгоритмы в VPN? Чем это отличается от IPsec с алгоритмом AES?
11. Почему заявленная производительность межсетевого экрана не соответствует производительности при включённых IPS, антивирусе и TLS-инспекции?

12. Что такое микросегментация и как NGFW помогает её реализовать?
13. Как по журналам восстановить картину инцидента? Какие данные необходимы и почему важна синхронизация времени?
14. Почему сам шлюз безопасности является объектом атаки? Какие меры защиты интерфейса управления необходимо применять?

Источники

1. Документация Kerio Control (GFI Software): https://support.keriocontrol.gfi.com
2. Документация «Континент 4» (версия 4.2.1): https://docs.securitycode.ru/products/kontinent_4_2_1/
3. Образ виртуального стенда «Континент 4» для ESXi: https://box.digital.mephi.ru/s/gAo2R38AwgaQPcF